

Security Assessment Report

Generated: 2026-05-05 23:28

Report ID: 9693c66d

Security Assessment Report

1. Executive Summary

An assessment was requested for the target path /workspace/uploads/4753d530f449 using automated tooling intended to run Bandit, Sonar, and Safety analyses. However, all three scan attempts failed due to an execution environment issue (name 'mcp_client' is not defined), and no codelevel findings were returned.

As a result, no confirmed vulnerabilities can be reported from the provided scan output. The primary security risk at this time is limited visibility into the codebase due to tool execution failure. Without successful scan output, the security posture cannot be reliably determined.

Overall Risk Level: Medium

This rating reflects the absence of validated findings, but also the inability to perform the intended automated security verification.

2. Risk Overview

Findings by Severity

Critical: 0

High: 0

Medium: 1

Low: 0

Informational: 3

Risk Interpretation

Critical / High: No confirmed exploitable issues were identified from the supplied results.

Medium: The security assessment process itself was impeded by scan execution failures, limiting assurance over the target's security posture.

Informational: Tooling and execution errors were observed, but these do not indicate

vulnerabilities in the target application; rather, they indicate assessment limitations.

3. Detailed Findings

Informational Findings

Finding 1 — Bandit Scan Execution Failure

Severity: Informational

CVSS Score (estimated): 0.0

OWASP Category:

A09: Security Logging and Monitoring Failures

A05: Security Misconfiguration

Affected Component:

/workspace/uploads/4753d530f449 — automated Bandit execution pipeline

Description:

The Bandit scan did not execute successfully.

The reported error was: MCP direct execution failed with details name 'mcp_client' is not defined.

This indicates a tooling or orchestration failure rather than an application vulnerability.

Because the scan did not run, potential Python security issues such as hardcoded secrets, unsafe deserialization, or insecure subprocess usage could not be assessed.

Impact:

No direct exploit impact on the target application is confirmed.

Security assurance is reduced because codelevel issues remain unverified.

From a business perspective, unresolved tooling failures can delay release decisions and leave latent vulnerabilities undiscovered.

Proof of Concept (if possible):

Rerunning the Bandit automation against the same path reproduces the failure before any security analysis occurs.

Recommended Remediation:

Fix the MCP integration issue by ensuring mcp_client is properly initialized and imported in the execution environment.

Validate the scan orchestration layer independently before rerunning security checks.
Confirm the target path is accessible and the scanning container has sufficient permissions.
Reexecute Bandit after repairing the execution pipeline.

Finding 2 — Sonar Scan Execution Failure

Severity: Informational

CVSS Score (estimated): 0.0

OWASP Category:

A05: Security Misconfiguration

A09: Security Logging and Monitoring Failures

Affected Component:

/workspace/uploads/4753d530f449 — automated Sonar execution pipeline

Description:

The Sonar scan failed with the same execution error: MCP direct execution failed and name 'mcp_client' is not defined.

No static analysis results were produced.

As a result, issues typically identified by Sonar, such as code smells, maintainability problems, and certain security hotspots, could not be evaluated.

Impact:

No confirmed security weakness is associated with the application itself.

The lack of Sonar output reduces confidence in the codebase's quality and security hygiene.

Defects that affect maintainability and security posture may remain undetected.

Proof of Concept (if possible):

Attempting to run the Sonar automation against the target reproduces the execution failure without returning analysis results.

Recommended Remediation:

Repair the MCP/automation integration responsible for invoking Sonar.

Verify scanner configuration, authentication, and environment dependencies.

Ensure the analysis job has access to the repository contents and required runtime components.

After remediation, rerun the analysis and review all flagged hotspots.

Finding 3 — Safety Dependency Scan Execution Failure

Severity: Informational

CVSS Score (estimated): 0.0

OWASP Category:

A05: Security Misconfiguration

A06: Vulnerable and Outdated Components

Affected Component:

/workspace/uploads/4753d530f449 — automated Safety dependency scanning pipeline

Description:

The Safety scan did not complete due to the same orchestration error: MCP direct execution failed with name 'mcp_client' is not defined.

No dependency vulnerability assessment was returned.

Therefore, installed Python package risks such as known CVEs, outdated libraries, or dependency exposure could not be verified.

Impact:

No direct application vulnerability is confirmed from the provided output.

Dependencyrelated risks may be present but unassessed.

This creates uncertainty around supplychain security and patch status.

Proof of Concept (if possible):

Running the Safety scan in the current environment reproduces the failure before dependency analysis begins.

Recommended Remediation:

Correct the MCP execution issue in the dependency scanning workflow.

Verify that the package environment and lockfiles are available to the scanner.

Rerun Safety against the project dependencies after the integration problem is resolved.

Establish routine dependency scanning in CI/CD to catch vulnerable packages early.

4. Recommendations (Global)

1. Restore Scanner Functionality

Resolve the mcp_client initialization/import issue.

Validate each scanner independently before integrating into automated workflows.

2. Implement DefenseinDepth Secure Coding Practices

Apply input validation and output encoding consistently.

Use parameterized queries and safe APIs to prevent injection issues.

Avoid insecure deserialization and unsafe dynamic execution patterns.

3. Strengthen Dependency Management

Maintain an uptodate dependency inventory.

Use pinned versions and regularly review security advisories.

Integrate automated dependency checks into CI/CD pipelines.

4. Improve Authentication and Access Control

Enforce least privilege for services, build agents, and runtime accounts.

Review rolebased access controls and privileged operations.

5. Enhance Security Visibility

Enable centralized logging and monitoring for scan jobs and application events.

Alert on repeated automation failures, since they can mask real security issues.

6. Adopt Routine Security Testing

Rerun static analysis, dependency scanning, and manual review after the tooling issue is resolved.

Include OWASP Top 10 testing coverage in release gating.

5. Conclusion

The provided automated scan results do not contain confirmed application vulnerabilities; however, all requested security tools failed to execute due to an environment/orchestration issue involving mcp_client. This limits the confidence of the assessment and prevents a meaningful validation of the target's security posture.

The most urgent action is to restore the scanning pipeline and rerun the assessments. Until that is completed, the application should be considered not fully verified, and residual security risk remains due to lack of visibility.